Seguridad Física y Lógica de la Información:

Fundamentos, Interdependencia y Políticas de Protección

Jorge Alejandro Torres Páez

Servicio Nacional de Aprendizaje (SENA)

Curso: Controles Informáticos

Ficha: 3525553

Instructor: Iván Alejandro

Junio 2026

Resumen

El presente trabajo analiza la importancia de la seguridad física y lógica de la información como dimensiones complementarias e interdependientes dentro de cualquier organización que gestione sistemas de información. A través de dos preguntas orientadoras, se argumenta que ninguna de estas dos dimensiones es suficiente por sí sola: una brecha en la seguridad física puede anular los controles lógicos más robustos, y viceversa. Asimismo, se desarrollan las principales políticas de seguridad que deben implementarse en el área de sistemas, alineadas con estándares internacionales como ISO/IEC 27001 e ISO/IEC 27002 y las directrices del Instituto Nacional de Estándares y Tecnología (NIST). Se concluye que la protección efectiva de la información requiere un modelo integrado que combine controles físicos, lógicos, humanos y procedimentales.

Palabras clave: *seguridad física, seguridad lógica, políticas de seguridad, ISO/IEC 27001, gestión de riesgos.*

Seguridad Física y Lógica de la Información: Fundamentos, Interdependencia y Políticas

Importancia de la seguridad física y lógica de la información

La información es uno de los activos más valiosos de cualquier organización moderna. Los sistemas de información almacenan y procesan datos que sustentan tanto la operación diaria como la toma de decisiones estratégicas, lo que hace que su protección sea una prioridad crítica. Esta protección debe abordarse desde dos perspectivas complementarias: la seguridad física y la seguridad lógica (International Organization for Standardization [ISO], 2022).

La seguridad física tiene por objetivo proteger la infraestructura tecnológica tangible de la organización: servidores, equipos de red, centros de datos, dispositivos de almacenamiento y cualquier componente hardware que soporte los sistemas de información. Sus mecanismos incluyen el control de acceso a instalaciones mediante tarjetas, biometría o guardias de seguridad; la videovigilancia; los sistemas contra incendios e inundaciones; y la gestión de la cadena de custodia de equipos y medios de almacenamiento. La seguridad física busca prevenir accesos no autorizados, robos, daños deliberados o accidentales y desastres naturales que puedan comprometer la disponibilidad del sistema (NIST, 2020).

La seguridad lógica, por su parte, protege la información a nivel de software y datos mediante mecanismos como la autenticación de usuarios, el control de acceso basado en roles,

el cifrado de datos en tránsito y en reposo, la gestión de permisos, los sistemas de detección de intrusiones (IDS) y los firewalls. Estos controles aseguran que solo los usuarios autorizados puedan acceder, modificar o transmitir información, y que los datos permanezcan íntegros y confidenciales durante todo su ciclo de vida.

La razón principal por la que ambas dimensiones son igualmente importantes radica en su interdependencia. Una organización puede implementar los controles lógicos más sofisticados —cifrado de extremo a extremo, autenticación multifactor, monitoreo continuo—, pero si una persona no autorizada logra ingresar físicamente a la sala de servidores, puede manipular el hardware directamente, extraer discos duros o interrumpir servicios críticos sin necesidad de vulnerar ningún sistema lógico. De manera inversa, una infraestructura física perfectamente resguardada no impide que un usuario interno con credenciales válidas acceda indebidamente a información confidencial si los controles lógicos de acceso son deficientes (ISO, 2022).

Un escenario frecuente en entornos reales ilustra esta interdependencia: la pérdida o el robo de credenciales combinado con fallas en el control físico de dispositivos puede derivar en filtración de información sensible, interrupción de servicios o incluso ataques de ransomware que afectan la continuidad del negocio. Por ello, la seguridad de la información debe concebirse como un modelo integrado que aborde simultáneamente ambas dimensiones, sin descuidar ninguna de ellas (NIST, 2020).

Políticas de seguridad en el área de sistemas para proteger la información

Las políticas de seguridad de la información son el conjunto de directrices, procedimientos y controles formalmente establecidos por una organización para gestionar los riesgos asociados al manejo de sus activos de información. Estas políticas deben estar alineadas con marcos normativos internacionales como la norma ISO/IEC 27001:2022, que establece los requisitos para un Sistema de Gestión de Seguridad de la Información (SGSI), y con las directrices del NIST SP 800-53, que define controles de seguridad y privacidad para sistemas de información (ISO, 2022; NIST, 2020).

Las principales políticas que debe establecer el área de sistemas son las siguientes:

- **Gestión de control de acceso bajo el principio de mínimo privilegio:** cada usuario debe tener acceso únicamente a los recursos y funciones estrictamente necesarios para desempeñar su rol. Este principio reduce el impacto potencial de incidentes internos y limita el alcance de posibles ataques externos que comprometan credenciales de usuario.

- **Autenticación segura y multifactor:** la implementación de contraseñas robustas debe complementarse con mecanismos de autenticación multifactor (MFA), que exigen al usuario verificar su identidad a través de dos o más factores independientes, reduciendo significativamente el riesgo de acceso no autorizado por robo de credenciales.

- **Política de copias de seguridad y recuperación ante desastres:** se deben establecer procedimientos de respaldo periódico de la información crítica, con verificación de integridad de las copias y planes de recuperación que garanticen la continuidad del negocio ante fallos del sistema, ataques o desastres.

- **Seguridad física de la infraestructura crítica:** los centros de datos y salas de servidores deben contar con control de ingreso restringido, monitoreo por cámaras de seguridad, registro cronológico de accesos y protección ambiental frente a incendios, inundaciones y variaciones eléctricas.

- **Monitoreo continuo y auditoría de sistemas:** el área de sistemas debe implementar herramientas de monitoreo que registren y analicen la actividad de los usuarios y del sistema, con el fin de detectar comportamientos anómalos, accesos sospechosos o intentos de intrusión en tiempo real.

- **Capacitación y concienciación en seguridad de la información:** dado que el factor humano es uno de los principales vectores de riesgo, los usuarios deben recibir formación periódica sobre buenas prácticas de seguridad, gestión de contraseñas, identificación de correos de phishing y manejo seguro de la información.

Según NIST (2020), la gestión de identidad y el control de acceso son elementos esenciales dentro de la protección de sistemas críticos, dado que reducen significativamente el

riesgo de accesos no autorizados cuando se implementan de forma conjunta con controles físicos. La norma ISO/IEC 27001 (ISO, 2022) complementa este enfoque al exigir que las políticas de seguridad sean documentadas, revisadas periódicamente y auditadas para asegurar su efectividad y adaptación a los cambios del entorno tecnológico y organizacional.

Conclusión

En conclusión, la seguridad física y la seguridad lógica no deben concebirse como capas independientes, sino como dimensiones complementarias de un único modelo de protección de la información. Una debilidad en cualquiera de las dos puede comprometer los tres pilares fundamentales de la seguridad de la información: la confidencialidad, la integridad y la disponibilidad. Las políticas de seguridad alineadas con estándares como ISO/IEC 27001 y NIST SP 800-53 proporcionan un marco estructurado para gestionar los riesgos de manera integral, combinando controles físicos, lógicos, humanos y procedimentales. Solo a través de este enfoque holístico es posible garantizar una protección efectiva y sostenida de los activos de información de la organización.

Referencias

International Organization for Standardization. (2022). *ISO/IEC 27001:2022 Information security management systems.* https://www.iso.org/standard/27001

Instituto Nacional de Estándares y Tecnología. (2020). *Security and privacy controls for information systems and organizations (NIST SP 800-53 Rev. 5).* https://doi.org/10.6028/NIST.SP.800-53r5

Laudon, K. C., & Laudon, J. P. (2020). *Sistemas de información gerencial* (16.ª ed.). Pearson Educación.